

Information Security Policy

FinFlow Ltd.

1. Purpose

This policy defines FinFlow Ltd's commitment to protecting the confidentiality, integrity and availability of information assets, including customer payment data, in line with ISO/IEC 27001:2022 and applicable regulatory requirements including UK GDPR.

2. Scope

This policy applies to all employees, contractors and third parties who access FinFlow's systems, data or infrastructure, and covers all information assets regardless of format or location, including cloud-hosted systems on AWS.

3. Policy Statements

3.1 Information Security Objectives

- Protect customer and company data from unauthorized access, disclosure, alteration or destruction.
- Ensure the availability of FinFlow's platform and services to customers.
- Comply with applicable legal, regulatory and contractual security requirements.
- Maintain customer trust through demonstrable, certifiable security practices.

3.2 Roles and Responsibilities

- The Head of Security owns this policy and is accountable for the information security programme.
- All employees are responsible for complying with this policy and reporting suspected security incidents.
- Line managers are responsible for ensuring their teams complete required security training.

3.3 Access Control

- Access to systems and data is granted on a least-privilege, role-based basis.
- Multi-factor authentication (MFA) is mandatory for all access to production systems, email and VPN.
- Access rights are reviewed quarterly and revoked within 24 hours of employee offboarding.

3.4 Data Protection

- Customer payment data is encrypted in transit (TLS 1.2+) and at rest (AES-256).
- Data is classified according to sensitivity and handled accordingly.
- Personal data is processed in accordance with UK GDPR and FinFlow's Data Protection Policy.

3.5 Third-Party and Supplier Security

- All suppliers with access to FinFlow data undergo a security risk assessment prior to onboarding.
- Data Processing Agreements (DPAs) are in place with all relevant sub-processors.

3.6 Compliance and Review

- This policy is reviewed at least annually or following a significant change to the business or threat landscape.
- Non-compliance may result in disciplinary action up to and including termination of employment or contract.

4. Related Documents

- Incident Response Policy
- Access Control Policy
- Data Protection Policy
- Risk Register

Incident Response Policy

FinFlow Ltd.

1. Purpose

This policy defines how FinFlow Ltd identifies, responds to, and recovers from information security incidents, minimising impact to customers, data and business operations, and ensuring compliance with regulatory breach notification requirements.

2. Scope

This policy applies to all suspected or confirmed information security incidents affecting FinFlow's systems, data or services, including incidents originating from third parties.

3. Incident Classification

- Critical: Confirmed data breach involving customer payment data, or full service outage.
- High: Suspected unauthorized access, malware detected on production systems.
- Medium: Policy violation, isolated phishing attempt with no confirmed compromise.
- Low: Minor policy deviation with no security impact.

4. Roles and Responsibilities

- Incident Response Lead (Head of Security): coordinates response, makes containment decisions, approves external communication.
- All employees: report suspected incidents immediately via the designated incident channel.
- Data Protection Officer: assesses regulatory notification obligations for incidents involving personal data.

5. Incident Response Process

5.1 Detection & Reporting

Incidents may be identified via automated monitoring/SIEM alerts, employee reports, or third-party notification. All suspected incidents must be reported within 1 hour of discovery.

5.2 Triage & Classification

The Incident Response Lead classifies the incident severity within 2 hours of report and assembles the response team as needed.

5.3 Containment

Immediate actions are taken to limit further impact, such as revoking compromised credentials, isolating affected systems, or disabling affected integrations.

5.4 Eradication & Recovery

The root cause is identified and remediated. Affected systems are restored from clean backups where necessary and validated before returning to production.

5.5 Notification

For Critical and High incidents involving personal data, the Data Protection Officer assesses notification obligations under UK GDPR (including the 72-hour ICO reporting requirement where applicable). Affected customers are notified in line with contractual and regulatory obligations.

5.6 Post-Incident Review

A post-incident review is conducted within 5 business days of resolution for all Critical and High incidents, documenting root cause, response effectiveness, and follow-up actions to prevent recurrence.

6. Response Time Targets

- Critical: Initial response within 30 minutes, containment within 4 hours.
- High: Initial response within 2 hours, containment within 24 hours.
- Medium: Initial response within 1 business day.
- Low: Reviewed within 5 business days.

7. Related Documents

- Information Security Policy
- Business Continuity Plan
- Data Protection Policy